CIA Part 1 – Governance, Risk Management, and Control

100 Hard Questions with Detailed Explanations

Study Deck

October 15, 2026

Format & Coverage

100 hard questions on Governance, Risk Management, and Control.

Each question is followed by a detailed explanation slide.

Coverage: governance structures, board/audit committee roles, ERM frameworks (COSO ERM, ISO 31000), risk appetite/tolerance, inherent/residual/control/detection risk, COSO Internal Control, control types, control deficiencies, material weaknesses, fraud risk, IT general controls, and governance failures.

Q1

Question: Which of the following best describes the primary responsibility for governance in an organization?

A. Management

B. The board of directors

C. Internal audit

D. External audit

Correct Answer: B

Q1 – Explanation

Correct: B. The board holds ultimate responsibility for governance, setting direction, oversight, and accountability.

A wrong: Management executes governance but does not own it.

C wrong: Internal audit provides assurance on governance.

D wrong: External audit provides independent opinion on financial statements.

Q2

Question: Which governance principle is most directly supported by having a majority of independent directors?

A. Transparency

B. Accountability

C. Objectivity in oversight

D. Profit maximization

Correct Answer: C

Q2 – Explanation

Correct: C. Independent directors reduce conflicts of interest and support objective oversight.

A wrong: Transparency is about disclosure.

B wrong: Accountability is about answerability.

D wrong: Profit is not a governance principle.

Q3

Question: The audit committee's primary role in governance is to:

A. Manage daily operations.

B. Oversee financial reporting, internal control, and audit functions.

C. Set product strategy.

D. Hire all staff.

Correct Answer: B

Q3 – Explanation

Correct: B. The audit committee oversees financial reporting, internal control, internal audit, and external audit.

A wrong: Operations are management's job.

C wrong: Strategy is the full board/management.

D wrong: Hiring is management/HR.

Q4

Question: Which of the following is the best evidence of effective governance?

A. High profit margins.

B. Independent board oversight and effective risk management.

C. Large market share.

D. Low employee turnover.

Correct Answer: B

Q4 – Explanation

Correct: B. Effective governance is demonstrated by independent oversight, accountability, and risk management.

A wrong: Profit is a result, not governance evidence.

C wrong: Market share is a performance metric.

D wrong: Turnover is HR-related.

Q5

Question: Which is NOT a principle of the OECD governance framework?

A. Ensuring the basis for an effective governance framework.

B. The rights of shareholders.

C. Equitable treatment of shareholders.

D. Maximizing executive bonuses.

Correct Answer: D

Q5 – Explanation

Correct: D. OECD principles cover shareholder rights, equitable treatment, disclosure, board responsibilities, etc., not executive bonuses.

A wrong: That is an OECD principle.

B wrong: That is an OECD principle.

C wrong: That is an OECD principle.

Q6

Question: Which best describes the difference between governance and management?

A. Governance sets direction and oversight; management executes.

B. Governance executes; management sets direction.

C. They are the same.

D. Governance is only for public companies.

Correct Answer: A

Q6 – Explanation

Correct: A. Governance sets direction, oversight, and accountability; management runs day-to-day operations.

B wrong: Roles are reversed.

C wrong: They are distinct.

D wrong: All organizations need governance.

Q7

Question: Which of the following is the best description of "enterprise risk management" (ERM)?

A. A process to identify, assess, and manage risks across the organization.

B. A one-time risk assessment.

C. A compliance checklist.

D. A financial audit.

Correct Answer: A

Q7 – Explanation

Correct: A. ERM is a structured, ongoing process to identify, assess, respond to, and monitor risks across the enterprise.

B wrong: ERM is ongoing.

C wrong: It is broader than compliance.

D wrong: Financial audit is assurance.

Q8

Question: In COSO ERM 2017, which is NOT one of the five components?

A. Governance and culture.

B. Strategy and objective-setting.

C. Performance.

D. Financial reporting.

Correct Answer: D

Q8 – Explanation

Correct: D. COSO ERM 2017 components: Governance & Culture, Strategy & Objective-Setting, Performance, Review & Revision, Information, Communication & Reporting.

A wrong: That is a component.

B wrong: That is a component.

C wrong: That is a component.

Q9

Question: Which best describes the difference between risk appetite and risk tolerance?

A. Appetite is the amount of risk willing to accept; tolerance is the acceptable variation around it.

B. They are the same.

C. Tolerance is set by the auditor.

D. Appetite is set by the auditor.

Correct Answer: A

Q9 – Explanation

Correct: A. Risk appetite is the amount/type of risk an entity is willing to accept; risk tolerance is the acceptable variation around that appetite.

B wrong: They are distinct.

C wrong: Tolerance is set by management/board.

D wrong: Appetite is set by the board.

Q10

Question: Which of the following best describes "residual risk"?

A. Risk before controls.

B. Risk remaining after controls.

C. Risk of fraud.

D. Risk of auditor error.

Correct Answer: B

Q10 – Explanation

Correct: B. Residual risk = inherent risk minus the effect of controls.

A wrong: That is inherent risk.

C wrong: Fraud is one type of risk.

D wrong: Auditor error is detection risk.

Q11

Question: Which is the best description of "control risk"?

A. Risk that a control fails to prevent or detect a misstatement.

B. Risk before controls.

C. Risk of fraud.

D. Risk of market loss.

Correct Answer: A

Q11 – Explanation

Correct: A. Control risk is the risk that a control will not prevent or detect a material misstatement on a timely basis.

B wrong: That is inherent risk.

C wrong: Fraud is a source.

D wrong: Market loss is market risk.

Q12

Question: Which is the best description of "detection risk"?

A. Risk that audit procedures fail to detect a misstatement.

B. Risk before controls.

C. Risk of fraud.

D. Risk of market loss.

Correct Answer: A

Q12 – Explanation

Correct: A. Detection risk is the risk that the auditor's procedures will not detect a material misstatement.

B wrong: That is inherent risk.

C wrong: Fraud is a source.

D wrong: Market loss is market risk.

Q13

Question: Which of the following is a preventive control?

A. Bank reconciliation.

B. Segregation of duties.

C. Variance analysis.

D. Exception report.

Correct Answer: B

Q13 – Explanation

Correct: B. Segregation of duties prevents fraud/error.

A wrong: Reconciliation is detective.

C wrong: Variance analysis is detective.

D wrong: Exception reports are detective.

Q14

Question: Which of the following is a detective control?

A. Authorization.

B. Physical safeguards.

C. Bank reconciliation.

D. Password policy.

Correct Answer: C

Q14 – Explanation

Correct: C. Reconciliation detects discrepancies after they occur.

A wrong: Authorization is preventive.

B wrong: Safeguards are preventive.

D wrong: Password policy is preventive.

Q15

Question: Which of the following is a corrective control?

A. Authorization.

B. Segregation of duties.

C. Backup and recovery procedures.

D. Password policy.

Correct Answer: C

Q15 – Explanation

Correct: C. Corrective controls restore systems/processes after an incident (e.g., backup recovery).

A wrong: Authorization is preventive.

B wrong: Segregation is preventive.

D wrong: Password policy is preventive.

Q16

Question: Which is the best description of "inherent risk"?

A. Risk before considering controls.

B. Risk after controls.

C. Risk of fraud.

D. Risk of market loss.

Correct Answer: A

Q16 – Explanation

Correct: A. Inherent risk is the risk of an event occurring before controls are applied.

B wrong: That is residual risk.

C wrong: Fraud is a source.

D wrong: Market loss is market risk.

Q17

Question: Which of the following is NOT a component of the COSO Internal Control – Integrated Framework?

A. Control environment.

B. Risk assessment.

C. Marketing strategy.

D. Monitoring.

Correct Answer: C

Q17 – Explanation

Correct: C. COSO's five components: Control Environment, Risk Assessment, Control Activities, Information & Communication, Monitoring.

A wrong: Control environment is COSO.

B wrong: Risk assessment is COSO.

D wrong: Monitoring is COSO.

Q18

Question: Which best describes "tone at the top"?

A. The CEO's salary.

B. Management's commitment to ethics and control.

C. The marketing slogan.

D. The IT password policy.

Correct Answer: B

Q18 – Explanation

Correct: B. Tone at the top is the control environment element reflecting leadership's ethics and commitment to control.

A wrong: Compensation is unrelated.

C wrong: Marketing slogans are not control environment.

D wrong: Password policy is one IT control.

Q19

Question: Which is a limitation of internal control?

A. Cost-benefit considerations.

B. Segregation of duties.

C. Physical safeguards.

D. Authorization procedures.

Correct Answer: A

Q19 – Explanation

Correct: A. Controls are limited by cost-benefit, human error, collusion, and management override.

B wrong: Segregation is a control.

C wrong: Safeguards are controls.

D wrong: Authorization is a control.

Q20

Question: Which is the best description of a "control deficiency"?

A. Design or operation does not prevent/detect misstatements timely.

B. A documented control.

C. A management disagreement.

D. Zero risk.

Correct Answer: A

Q20 – Explanation

Correct: A. A deficiency exists when a control is missing, poorly designed, or not operating so misstatements are not prevented/detected timely.

B wrong: Documentation is a strength.

C wrong: Disagreement doesn't create a deficiency.

D wrong: Zero risk is unrealistic.

Q21

Question: Which is the best description of a "material weakness"?

A. A minor deficiency.

B. A deficiency creating a reasonable possibility of material misstatement.

C. A documentation gap.

D. A training issue.

Correct Answer: B

Q21 – Explanation

Correct: B. A material weakness creates a reasonable possibility that a material misstatement will not be prevented or detected timely.

A wrong: Minor deficiencies are less severe.

C wrong: Documentation gaps may be deficiencies but not automatically material.

D wrong: Training issues may contribute but are not the definition.

Q22

Question: Which is the best description of a "significant deficiency"?

A. Less severe than a material weakness but important enough to report.

B. Always material.

C. A minor clerical error.

D. Only relevant to IT.

Correct Answer: A

Q22 – Explanation

Correct: A. A significant deficiency is less severe than a material weakness but important enough to bring to the attention of those charged with governance.

B wrong: It is less severe than material.

C wrong: Minor clerical errors are not significant deficiencies.

D wrong: It applies beyond IT.

Q23

Question: Which is the best description of "fraud risk"?

A. Risk of intentional misstatement or theft.

B. Risk of human error.

C. Risk of market loss.

D. Risk of IT failure.

Correct Answer: A

Q23 – Explanation

Correct: A. Fraud risk is the risk of intentional acts (misstatement, theft) by individuals.

B wrong: Human error is not fraud.

C wrong: Market loss is market risk.

D wrong: IT failure is operational risk.

Q24

Question: The fraud triangle consists of:

A. Pressure, opportunity, rationalization.

B. Risk, control, detection.

C. Plan, do, check.

D. Cash, inventory, receivables.

Correct Answer: A

Q24 – Explanation

Correct: A. Cressey's fraud triangle: pressure (incentive), opportunity, and rationalization.

B wrong: That's the audit risk model.

C wrong: That's the Deming/PDCA cycle.

D wrong: Those are balance sheet accounts.

Q25

Question: Which best describes the IIA's role in ERM?

A. Own the ERM process.

B. Provide assurance and consulting on ERM.

C. Set risk appetite.

D. Approve risk responses.

Correct Answer: B

Q25 – Explanation

Correct: B. Internal audit provides assurance and consulting on ERM but should not own it or set appetite.

A wrong: Management owns ERM.

C wrong: The board sets risk appetite.

D wrong: Management approves responses.

Q26

Question: Which is the best description of "risk response"?

A. Avoid, reduce, share, or accept risk.

B. Ignore risk.

C. Transfer all risk.

D. Eliminate all risk.

Correct Answer: A

Q26 – Explanation

Correct: A. The four responses are avoid, reduce (mitigate), share (transfer), and accept.

B wrong: Ignoring is not valid.

C wrong: Transfer is only one option.

D wrong: Elimination is not always possible.

Q27

Question: Which best describes "risk register"?

A. A list of identified risks and their responses.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q27 – Explanation

Correct: A. A risk register documents identified risks, their assessment, owners, and responses.

B wrong: The audit plan is separate.

C wrong: The marketing plan is unrelated.

D wrong: Financial statements are outputs.

Q28

Question: Which best describes "risk assessment" in COSO?

A. Identifying and analyzing risks to objectives.

B. Preparing financial statements.

C. Hiring staff.

D. Auditing the financial statements.

Correct Answer: A

Q28 – Explanation

Correct: A. Risk assessment identifies and analyzes risks to achieving objectives.

B wrong: Financial statement prep is management.

C wrong: Hiring is a control activity.

D wrong: Auditing is assurance.

Q29

Question: Which is the best description of "control activities"?

A. Policies and procedures that help ensure management directives are carried out.

B. The board's meeting schedule.

C. The audit plan.

D. The marketing plan.

Correct Answer: A

Q29 – Explanation

Correct: A. Control activities are policies and procedures that help ensure management directives are executed.

B wrong: Meeting schedules are not control activities.

C wrong: The audit plan is a planning document.

D wrong: Marketing plans are unrelated.

Q30

Question: Which best describes "monitoring" in COSO?

A. Assessing the quality of internal control over time.

B. Preparing the budget.

C. Hiring staff.

D. Setting the risk appetite.

Correct Answer: A

Q30 – Explanation

Correct: A. Monitoring assesses the quality of internal control performance over time.

B wrong: Budgeting is a control activity.

C wrong: Hiring is a control activity.

D wrong: Risk appetite is set by the board.

Q31

Question: Which best describes "information and communication" in COSO?

A. Identifying, capturing, and communicating relevant information.

B. The marketing campaign.

C. The IT budget.

D. The audit report.

Correct Answer: A

Q31 – Explanation

Correct: A. Information and communication ensures relevant information is identified, captured, and communicated timely.

B wrong: Marketing is unrelated.

C wrong: IT budget is a resource.

D wrong: The audit report is an output.

Q32

Question: Which best describes "control environment"?

A. The tone of the organization, influencing control consciousness.

B. The IT infrastructure.

C. The audit committee.

D. The external auditor's opinion.

Correct Answer: A

Q32 – Explanation

Correct: A. The control environment is the tone at the top – integrity, ethical values, and commitment to competence.

B wrong: IT infrastructure is part of control activities.

C wrong: The audit committee is part of governance.

D wrong: External opinion is not the environment.

Q33

Question: Which best describes "internal control"?

A. A process designed to provide reasonable assurance regarding objectives.

B. A guarantee of no fraud.

C. The external audit opinion.

D. The marketing plan.

Correct Answer: A

Q33 – Explanation

Correct: A. Internal control is a process designed to provide reasonable assurance regarding operations, reporting, and compliance objectives.

B wrong: No control guarantees no fraud.

C wrong: External opinion is separate.

D wrong: Marketing is unrelated.

Q34

Question: Which is the best description of "compliance risk"?

A. Risk of violating laws, regulations, or policies.

B. Risk of losing market share.

C. Risk of IT failure.

D. Risk of fraud.

Correct Answer: A

Q34 – Explanation

Correct: A. Compliance risk is the risk of violating laws, regulations, rules, or policies.

B wrong: Market share is strategic risk.

C wrong: IT failure is operational/technology risk.

D wrong: Fraud is its own category.

Q35

Question: Which is the best description of "operational risk"?

A. Risk of loss from inadequate or failed processes, people, or systems.

B. Risk of losing market share.

C. Risk of violating laws.

D. Risk of fraud.

Correct Answer: A

Q35 – Explanation

Correct: A. Operational risk arises from inadequate or failed internal processes, people, systems, or external events.

B wrong: Market share is strategic.

C wrong: Legal violations are compliance risk.

D wrong: Fraud is a subset.

Q36

Question: Which is the best description of "strategic risk"?

A. Risk of failing to achieve strategic objectives.

B. Risk of IT failure.

C. Risk of fraud.

D. Risk of violating laws.

Correct Answer: A

Q36 – Explanation

Correct: A. Strategic risk is the risk of failing to achieve strategic objectives.

B wrong: IT failure is operational.

C wrong: Fraud is its own category.

D wrong: Legal violations are compliance.

Q37

Question: Which is the best description of "reputational risk"?

A. Risk of damage to the organization's reputation.

B. Risk of IT failure.

C. Risk of fraud.

D. Risk of violating laws.

Correct Answer: A

Q37 – Explanation

Correct: A. Reputational risk is the risk of damage to the organization's image, brand, or public trust.

B wrong: IT failure is operational.

C wrong: Fraud is a separate category.

D wrong: Legal violations are compliance risk.

Q38

Question: Which is the best description of "risk treatment"?

A. Selecting and implementing measures to modify risk.

B. Ignoring risk.

C. Transferring all risk.

D. Eliminating all risk.

Correct Answer: A

Q38 – Explanation

Correct: A. Risk treatment involves selecting and implementing measures to modify risk (avoid, reduce, share, accept).

B wrong: Ignoring is not treatment.

C wrong: Transfer is one option.

D wrong: Elimination is not always possible.

Q39

Question: Which best describes the "three lines model"?

A. Management, risk/compliance, internal audit.

B. Board, CEO, CFO.

C. External audit, internal audit, regulators.

D. Marketing, sales, operations.

Correct Answer: A

Q39 – Explanation

Correct: A. The Three Lines Model: first line (management/operations), second line (risk/compliance), third line (internal audit).

B wrong: Those are roles, not the model.

C wrong: External audit is outside the model.

D wrong: Those are functions, not the model.

Q40

Question: Which is the best description of the first line in the Three Lines Model?

A. Management owns and manages risk.

B. Risk/compliance oversees risk.

C. Internal audit provides assurance.

D. External audit provides opinion.

Correct Answer: A

Q40 – Explanation

Correct: A. The first line is management, which owns and manages risk.

B wrong: Risk/compliance is the second line.

C wrong: Internal audit is the third line.

D wrong: External audit is outside the model.

Q41

Question: Which is the best description of the second line in the Three Lines Model?

A. Risk/compliance functions that oversee and challenge risk.

B. Management owns risk.

C. Internal audit provides assurance.

D. External audit provides opinion.

Correct Answer: A

Q41 – Explanation

Correct: A. The second line is risk/compliance, which oversees and challenges risk management.

B wrong: Management is the first line.

C wrong: Internal audit is the third line.

D wrong: External audit is outside the model.

Q42

Question: Which is the best description of the third line in the Three Lines Model?

A. Internal audit provides independent assurance.

B. Management owns risk.

C. Risk/compliance oversees risk.

D. External audit provides opinion.

Correct Answer: A

Q42 – Explanation

Correct: A. The third line is internal audit, providing independent assurance.

B wrong: Management is the first line.

C wrong: Risk/compliance is the second line.

D wrong: External audit is outside the model.

Q43

Question: Which best describes "governance"?

A. The processes and structures to direct and control the organization.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q43 – Explanation

Correct: A. Governance encompasses the processes and structures used to direct, control, and hold the organization accountable.

B wrong: The audit plan is a tool.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q44

Question: Which is the best description of "board oversight"?

A. Monitoring management and ensuring accountability.

B. Managing daily operations.

C. Preparing workpapers.

D. Hiring all staff.

Correct Answer: A

Q44 – Explanation

Correct: A. Board oversight monitors management and ensures accountability to stakeholders.

B wrong: Daily operations are management's job.

C wrong: Workpapers are internal audit's.

D wrong: Hiring is management/HR.

Q45

Question: Which best describes "transparency" in governance?

A. Timely and accurate disclosure of material information.

B. Hiding information.

C. Only disclosing good news.

D. Disclosing only to management.

Correct Answer: A

Q45 – Explanation

Correct: A. Transparency is timely and accurate disclosure of material information to stakeholders.

B wrong: Hiding is the opposite.

C wrong: Selective disclosure violates transparency.

D wrong: Disclosure is to stakeholders.

Q46

Question: Which best describes "accountability" in governance?

A. Answerability for decisions and actions.

B. Hiding decisions.

C. Avoiding responsibility.

D. Blaming others.

Correct Answer: A

Q46 – Explanation

Correct: A. Accountability is answerability for decisions and actions.

B wrong: Hiding is the opposite.

C wrong: Avoiding responsibility is the opposite.

D wrong: Blaming others is not accountability.

Q47

Question: Which best describes "fairness" in governance?

A. Equitable treatment of stakeholders.

B. Favoring insiders.

C. Ignoring minority shareholders.

D. Hiding conflicts.

Correct Answer: A

Q47 – Explanation

Correct: A. Fairness is equitable treatment of all stakeholders, including minority shareholders.

B wrong: Favoring insiders is the opposite.

C wrong: Ignoring minorities is the opposite.

D wrong: Hiding conflicts is unethical.

Q48

Question: Which best describes "responsibility" in governance?

A. Acting ethically and in the best interest of the organization.

B. Acting in self-interest.

C. Ignoring stakeholders.

D. Hiding information.

Correct Answer: A

Q48 – Explanation

Correct: A. Responsibility is acting ethically and in the best interest of the organization and its stakeholders.

B wrong: Self-interest is not responsibility.

C wrong: Ignoring stakeholders is the opposite.

D wrong: Hiding is unethical.

Q49

Question: Which best describes "risk culture"?

A. Shared values and behaviors regarding risk.

B. The risk register.

C. The audit plan.

D. The marketing plan.

Correct Answer: A

Q49 – Explanation

Correct: A. Risk culture is the shared values, beliefs, and behaviors regarding risk across the organization.

B wrong: The risk register is a tool.

C wrong: The audit plan is separate.

D wrong: Marketing is unrelated.

Q50

Question: Which best describes "risk appetite statement"?

A. A formal statement of the amount/type of risk the entity is willing to accept.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q50 – Explanation

Correct: A. A risk appetite statement formally documents the amount and type of risk the entity is willing to accept.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q51

Question: Which is NOT a type of risk response?

A. Avoid.

B. Reduce.

C. Ignore.

D. Accept.

Correct Answer: C

Q51 – Explanation

Correct: C. Ignoring is not a valid risk response. The four responses are avoid, reduce, share, accept.

A wrong: Avoid is a response.

B wrong: Reduce is a response.

D wrong: Accept is a response.

Q52

Question: Which best describes "risk owner"?

A. The person accountable for managing a specific risk.

B. The auditor.

C. The board.

D. The external regulator.

Correct Answer: A

Q52 – Explanation

Correct: A. A risk owner is the person accountable for managing a specific risk.

B wrong: The auditor provides assurance.

C wrong: The board sets appetite.

D wrong: Regulators are external.

Q53

Question: Which best describes "risk map"?

A. A visual representation of risks by likelihood and impact.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q53 – Explanation

Correct: A. A risk map plots risks by likelihood and impact to prioritize them.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q54

Question: Which best describes "key risk indicator" (KRI)?

A. A metric that provides early warning of increasing risk.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q54 – Explanation

Correct: A. A KRI is a metric that provides early warning of increasing risk exposure.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q55

Question: Which best describes "risk-based internal auditing"?

A. Aligning audit activities with the organization's risk profile.

B. Auditing everything equally.

C. Ignoring risk.

D. Auditing only financial areas.

Correct Answer: A

Q55 – Explanation

Correct: A. Risk-based auditing aligns audit activities with the organization's risk profile.

B wrong: Auditing everything equally is not risk-based.

C wrong: Ignoring risk is the opposite.

D wrong: Auditing only financial areas is too narrow.

Q56

Question: Which best describes "control self-assessment" (CSA)?

A. A workshop-based approach where management assesses controls.

B. An external audit technique.

C. A type of fraud.

D. A regulatory filing.

Correct Answer: A

Q56 – Explanation

Correct: A. CSA engages management/process owners in assessing their own controls, often in facilitated workshops.

B wrong: CSA is internal.

C wrong: It is not fraud.

D wrong: It is not a filing.

Q57

Question: Which best describes "control gap"?

A. A missing or inadequate control.

B. A documented control.

C. A management disagreement.

D. Zero risk.

Correct Answer: A

Q57 – Explanation

Correct: A. A control gap is a missing or inadequate control that leaves risk unmitigated.

B wrong: Documentation is a strength.

C wrong: Disagreement doesn't create a gap.

D wrong: Zero risk is unrealistic.

Q58

Question: Which best describes "compensating control"?

A. A control that mitigates risk when the primary control is missing.

B. A documented control.

C. A management disagreement.

D. Zero risk.

Correct Answer: A

Q58 – Explanation

Correct: A. A compensating control mitigates risk when the primary control is missing or weak.

B wrong: Documentation is separate.

C wrong: Disagreement doesn't create a control.

D wrong: Zero risk is unrealistic.

Q59

Question: Which best describes "key control"?

A. A control essential to mitigating a significant risk.

B. A minor control.

C. A management disagreement.

D. Zero risk.

Correct Answer: A

Q59 – Explanation

Correct: A. A key control is essential to mitigating a significant risk to an acceptable level.

B wrong: Minor controls are not key.

C wrong: Disagreement doesn't create a control.

D wrong: Zero risk is unrealistic.

Q60

Question: Which best describes "segregation of duties"?

A. Separating authorization, custody, and record-keeping.

B. Combining all duties in one person.

C. Ignoring duties.

D. Outsourcing.

Correct Answer: A

Q60 – Explanation

Correct: A. Segregation of duties separates authorization, custody, and record-keeping to prevent fraud/error.

B wrong: Combining duties is the opposite.

C wrong: Ignoring is not a control.

D wrong: Outsourcing is a separate decision.

Q61

Question: Which best describes "IT general controls" (ITGC)?

A. Controls over access, change management, and operations.

B. Controls over financial reporting only.

C. Controls over marketing.

D. Controls over HR.

Correct Answer: A

Q61 – Explanation

Correct: A. ITGCs cover access to programs/data, program changes, and computer operations.

B wrong: ITGCs are broader than financial reporting.

C wrong: Marketing is unrelated.

D wrong: HR is unrelated.

Q62

Question: Which best describes "application control"?

A. A control embedded in an application to prevent/detect errors.

B. A control over IT operations.

C. A control over marketing.

D. A control over HR.

Correct Answer: A

Q62 – Explanation

Correct: A. Application controls are embedded in applications (e.g., input validation, edit checks) to prevent/detect errors.

B wrong: IT operations controls are ITGCs.

C wrong: Marketing is unrelated.

D wrong: HR is unrelated.

Q63

Question: Which best describes "ITGC access control"?

A. Controls over who can access programs and data.

B. Controls over marketing.

C. Controls over HR.

D. Controls over financial reporting.

Correct Answer: A

Q63 – Explanation

Correct: A. Access controls manage who can access programs and data, and what they can do.

B wrong: Marketing is unrelated.

C wrong: HR is unrelated.

D wrong: Financial reporting is one area, not the definition.

Q64

Question: Which best describes "change management control"?

A. Controls over changes to applications and systems.

B. Controls over marketing.

C. Controls over HR.

D. Controls over financial reporting.

Correct Answer: A

Q64 – Explanation

Correct: A. Change management controls ensure changes to applications/systems are authorized, tested, approved, and documented.

B wrong: Marketing is unrelated.

C wrong: HR is unrelated.

D wrong: Financial reporting is one area.

Q65

Question: Which best describes "IT operations control"?

A. Controls over processing, backup, and recovery.

B. Controls over marketing.

C. Controls over HR.

D. Controls over financial reporting.

Correct Answer: A

Q65 – Explanation

Correct: A. IT operations controls cover processing schedules, backup, recovery, and incident management.

B wrong: Marketing is unrelated.

C wrong: HR is unrelated.

D wrong: Financial reporting is one area.

Q66

Question: Which best describes "governance failure"?

A. Breakdown in oversight, accountability, or ethics.

B. A minor control deficiency.

C. A documentation gap.

D. A training issue.

Correct Answer: A

Q66 – Explanation

Correct: A. Governance failure is a breakdown in oversight, accountability, or ethics, often leading to scandals.

B wrong: Minor deficiencies are not governance failures.

C wrong: Documentation gaps are not governance failures.

D wrong: Training issues are not governance failures.

Q67

Question: Which best describes "whistleblowing" in governance?

A. Reporting illegal or unethical activity through proper channels.

B. Leaking to the media.

C. Ignoring wrongdoing.

D. Confronting the suspect.

Correct Answer: A

Q67 – Explanation

Correct: A. Whistleblowing is reporting illegal/unethical activity through internal channels (or regulators if internal channels fail).

B wrong: Media leaks are a last resort.

C wrong: Ignoring is unethical.

D wrong: Confronting the suspect can compromise the investigation.

Q68

Question: Which best describes "ethics program"?

A. A formal program to promote ethical behavior and compliance.

B. A marketing campaign.

C. A financial audit.

D. A training session.

Correct Answer: A

Q68 – Explanation

Correct: A. An ethics program promotes ethical behavior and compliance through codes, training, reporting, and enforcement.

B wrong: Marketing is unrelated.

C wrong: Financial audit is assurance.

D wrong: Training is one element.

Q69

Question: Which best describes "code of conduct"?

A. A formal statement of expected behavior.

B. A marketing plan.

C. A financial audit.

D. A training session.

Correct Answer: A

Q69 – Explanation

Correct: A. A code of conduct formally states expected behavior for employees and stakeholders.

B wrong: Marketing is unrelated.

C wrong: Financial audit is assurance.

D wrong: Training is one element.

Q70

Question: Which best describes "tone at the top" in governance?

A. Leadership's commitment to ethics and control.

B. The CEO's salary.

C. The marketing slogan.

D. The IT password policy.

Correct Answer: A

Q70 – Explanation

Correct: A. Tone at the top is leadership's commitment to ethics and control.

B wrong: Compensation is unrelated.

C wrong: Marketing slogans are not tone at the top.

D wrong: Password policy is one IT control.

Q71

Question: Which best describes "risk oversight"?

A. The board's monitoring of management's risk management.

B. The auditor's risk assessment.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q71 – Explanation

Correct: A. Risk oversight is the board's monitoring of management's risk management activities.

B wrong: The auditor's risk assessment is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q72

Question: Which best describes "risk governance"?

A. The framework for how risk is managed and overseen.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q72 – Explanation

Correct: A. Risk governance is the framework for how risk is managed and overseen across the organization.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q73

Question: Which best describes "risk management framework"?

A. A structured approach to identifying, assessing, and managing risk.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q73 – Explanation

Correct: A. A risk management framework is a structured approach to identifying, assessing, responding to, and monitoring risk.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q74

Question: Which best describes "COSO ERM 2017"?

A. A framework integrating risk with strategy and performance.

B. A financial reporting framework.

C. A marketing framework.

D. An HR framework.

Correct Answer: A

Q74 – Explanation

Correct: A. COSO ERM 2017 integrates risk with strategy-setting and performance.

B wrong: Financial reporting is COSO IC.

C wrong: Marketing is unrelated.

D wrong: HR is unrelated.

Q75

Question: Which best describes "ISO 31000"?

A. An international risk management standard.

B. A financial reporting standard.

C. A marketing standard.

D. An HR standard.

Correct Answer: A

Q75 – Explanation

Correct: A. ISO 31000 is an international standard providing principles and guidelines for risk management.

B wrong: Financial reporting is separate.

C wrong: Marketing is unrelated.

D wrong: HR is unrelated.

Q76

Question: Which best describes "risk-based audit plan"?

A. An audit plan aligned with the organization's risk profile.

B. An audit plan based on management requests.

C. An audit plan based on prior findings.

D. An audit plan based on budget.

Correct Answer: A

Q76 – Explanation

Correct: A. A risk-based audit plan aligns audit activities with the organization's risk profile.

B wrong: Management requests are considered but not primary.

C wrong: Prior findings inform but risk drives.

D wrong: Budget is a constraint.

Q77

Question: Which best describes "assurance mapping"?

A. Aligning assurance activities to risks and controls.

B. Mapping the marketing plan.

C. Mapping the HR plan.

D. Mapping the financial statements.

Correct Answer: A

Q77 – Explanation

Correct: A. Assurance mapping aligns assurance activities (internal audit, risk, compliance, external audit) to risks and controls.

B wrong: Marketing is unrelated.

C wrong: HR is unrelated.

D wrong: Financial statements are outputs.

Q78

Question: Which best describes "combined assurance"?

A. Coordinating assurance from multiple providers.

B. A single assurance provider.

C. A marketing plan.

D. A financial statement.

Correct Answer: A

Q78 – Explanation

Correct: A. Combined assurance coordinates assurance from management, risk, compliance, internal audit, and external audit.

B wrong: Multiple providers are involved.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q79

Question: Which best describes "governance, risk, and control" (GRC)?

A. An integrated approach to governance, risk, and compliance.

B. A marketing plan.

C. A financial statement.

D. An HR plan.

Correct Answer: A

Q79 – Explanation

Correct: A. GRC is an integrated approach to governance, risk management, and compliance.

B wrong: Marketing is unrelated.

C wrong: Financial statements are outputs.

D wrong: HR is unrelated.

Q80

Question: Which best describes "risk-based internal audit"?

A. Auditing areas of highest risk first.

B. Auditing everything equally.

C. Auditing only financial areas.

D. Ignoring risk.

Correct Answer: A

Q80 – Explanation

Correct: A. Risk-based internal audit focuses on areas of highest risk to the organization.

B wrong: Auditing everything equally is not risk-based.

C wrong: Auditing only financial is too narrow.

D wrong: Ignoring risk is the opposite.

Q81

Question: Which best describes "residual risk vs. inherent risk"?

A. Residual = after controls; inherent = before controls.

B. Residual = before controls; inherent = after controls.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q81 – Explanation

Correct: A. Residual risk is after controls; inherent risk is before controls.

B wrong: Definitions are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q82

Question: Which best describes "risk-based audit planning"?

A. Prioritizing audit engagements based on risk.

B. Prioritizing audits based on budget.

C. Prioritizing audits based on management requests.

D. Prioritizing audits based on prior findings.

Correct Answer: A

Q82 – Explanation

Correct: A. Risk-based planning prioritizes engagements based on risk to the organization.

B wrong: Budget is a constraint.

C wrong: Management requests are considered.

D wrong: Prior findings inform but risk drives.

Q83

Question: Which best describes "governance framework"?

A. A structure for directing and controlling the organization.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q83 – Explanation

Correct: A. A governance framework is the structure for directing, controlling, and holding the organization accountable.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q84

Question: Which best describes "board committee"?

A. A sub-group of the board focused on specific oversight areas.

B. A management committee.

C. An audit team.

D. A marketing team.

Correct Answer: A

Q84 – Explanation

Correct: A. Board committees (audit, risk, compensation, nominating) focus on specific oversight areas.

B wrong: Management committees are separate.

C wrong: Audit teams are internal audit.

D wrong: Marketing teams are unrelated.

Q85

Question: Which best describes "audit committee charter"?

A. A document defining the audit committee's purpose and responsibilities.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q85 – Explanation

Correct: A. The audit committee charter defines its purpose, authority, and responsibilities.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q86

Question: Which best describes "governance code"?

A. A formal statement of governance principles and practices.

B. The audit plan.

C. The marketing plan.

D. The financial statements.

Correct Answer: A

Q86 – Explanation

Correct: A. A governance code formally states governance principles and practices.

B wrong: The audit plan is separate.

C wrong: Marketing is unrelated.

D wrong: Financial statements are outputs.

Q87

Question: Which best describes "stakeholder"?

A. A party with an interest in the organization.

B. Only shareholders.

C. Only management.

D. Only regulators.

Correct Answer: A

Q87 – Explanation

Correct: A. Stakeholders include shareholders, employees, customers, suppliers, regulators, and communities.

B wrong: Shareholders are one group.

C wrong: Management is one group.

D wrong: Regulators are one group.

Q88

Question: Which best describes "shareholder vs. stakeholder"?

A. Shareholders own equity; stakeholders have an interest.

B. They are the same.

C. Stakeholders own equity.

D. Shareholders have no interest.

Correct Answer: A

Q88 – Explanation

Correct: A. Shareholders own equity; stakeholders include anyone with an interest (employees, customers, etc.).

B wrong: They are distinct.

C wrong: Stakeholders don't necessarily own equity.

D wrong: Shareholders have an interest.

Q89

Question: Which best describes "agency problem"?

A. Conflict of interest between principals (shareholders) and agents (management).

B. A marketing problem.

C. A financial statement error.

D. An HR issue.

Correct Answer: A

Q89 – Explanation

Correct: A. The agency problem is the conflict between principals (shareholders) and agents (management) due to differing interests.

B wrong: Marketing is unrelated.

C wrong: Financial statement errors are separate.

D wrong: HR is unrelated.

Q90

Question: Which best describes "monitoring" in the context of governance?

A. Ongoing oversight of management and controls.

B. Preparing the budget.

C. Hiring staff.

D. Setting the risk appetite.

Correct Answer: A

Q90 – Explanation

Correct: A. Monitoring is ongoing oversight of management and controls by the board and others.

B wrong: Budgeting is a control activity.

C wrong: Hiring is a control activity.

D wrong: Risk appetite is set by the board.

Q91

Question: Which best describes "governance and risk" linkage?

A. Governance sets the tone and oversight for risk management.

B. Governance is separate from risk.

C. Risk is only the auditor's job.

D. Governance is only the board's job.

Correct Answer: A

Q91 – Explanation

Correct: A. Governance sets the tone and oversight for risk management, including appetite and accountability.

B wrong: They are linked.

C wrong: Risk is management's job.

D wrong: Governance involves the board and management.

Q92

Question: Which best describes "control environment" vs. "control activities"?

A. Environment = tone; activities = policies/procedures.

B. Environment = policies; activities = tone.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q92 – Explanation

Correct: A. Control environment is the tone at the top; control activities are policies/procedures.

B wrong: Definitions are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q93

Question: Which best describes "risk assessment" vs. "risk response"?

A. Assessment = identify/analyze; response = avoid/reduce/share/accept.

B. Assessment = response; response = assessment.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q93 – Explanation

Correct: A. Assessment identifies and analyzes risk; response selects a treatment (avoid, reduce, share, accept).

B wrong: Definitions are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q94

Question: Which best describes "control" vs. "risk"?

A. Control mitigates risk.

B. Risk mitigates control.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q94 – Explanation

Correct: A. Controls mitigate risk to an acceptable level.

B wrong: Risk does not mitigate control.

C wrong: They are distinct.

D wrong: Both matter.

Q95

Question: Which best describes "governance" vs. "management"?

A. Governance = oversight; management = execution.

B. Governance = execution; management = oversight.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q95 – Explanation

Correct: A. Governance provides oversight; management executes operations.

B wrong: Roles are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q96

Question: Which best describes "risk appetite" vs. "risk tolerance"?

A. Appetite = willing to accept; tolerance = acceptable variation.

B. Appetite = variation; tolerance = willingness.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q96 – Explanation

Correct: A. Risk appetite is the amount/type of risk willing to accept; risk tolerance is the acceptable variation around it.

B wrong: Definitions are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q97

Question: Which best describes "inherent risk" vs. "residual risk"?

A. Inherent = before controls; residual = after controls.

B. Inherent = after controls; residual = before controls.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q97 – Explanation

Correct: A. Inherent risk is before controls; residual risk is after controls.

B wrong: Definitions are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q98

Question: Which best describes "control risk" vs. "detection risk"?

A. Control risk = control fails; detection risk = auditor fails to detect.

B. Control risk = auditor fails; detection risk = control fails.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q98 – Explanation

Correct: A. Control risk is the risk a control fails; detection risk is the risk the auditor fails to detect a misstatement.

B wrong: Definitions are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q99

Question: Which best describes "preventive" vs. "detective" controls?

A. Preventive = stop; detective = find.

B. Preventive = find; detective = stop.

C. They are the same.

D. Neither matters.

Correct Answer: A

Q99 – Explanation

Correct: A. Preventive controls stop errors/fraud; detective controls find them after they occur.

B wrong: Definitions are reversed.

C wrong: They are distinct.

D wrong: Both matter.

Q100

Question: Which of the following best summarizes governance, risk management, and control?

A. Governance sets direction and oversight; risk management identifies and treats risk; control mitigates risk.

B. Governance executes; risk management ignores; control does nothing.

C. Governance is optional; risk management is optional; control is optional.

D. Governance is only for public companies.

Correct Answer: A

Q100 – Explanation

Correct: A. Governance sets direction and oversight; risk management identifies and treats risk; controls mitigate risk to acceptable levels.

B wrong: The roles are misrepresented.

C wrong: All three are essential.

D wrong: All organizations need governance.

End

End of 100-Question Governance, Risk Management, and Control Deck

Review weak areas and re-test.

Add more questions by copying the Q/Explanation frame pairs.